

資通安全職能訓練

《資通安全概論》

自我評量測驗試題

中華民國 115 年 8 月

數位發展部資通安全署

目 次

第 1 單元：資通安全基本觀念.....	3
第 2 單元：資通安全相關法規.....	5
第 3 單元：資通安全風險管理.....	7
第 4 單元：資通安全管理面暨認知與訓練應辦事項.....	9
第 5 單元：資通系統防護控制措施.....	12
第 6 單元：資通安全技術面應辦事項-資通安全防護及偵測.....	14
第 7 單元：資通安全技術面應辦事項-安全性檢測及資通安全健診.....	16
第 8 單元：資訊委外安全管理.....	19
第 9 單元：資通安全事件通報及應變.....	22

第 1 單元：資通安全基本觀念

1. (C) 依據《資通安全管理法》第 3 條第 1 項的定義，以下何者最能完整描述「資通系統」？
 - (A) 指用以儲存及流通資訊之硬體設備。
 - (B) 指用以傳輸或分享資訊之網路軟體。
 - (C) 指用以蒐集、控制、傳輸、儲存、流通、刪除資訊或對資訊為其他處理、使用或分享之系統。
 - (D) 指與資訊之蒐集、控制、傳輸、儲存、流通、刪除、其他處理、使用或分享相關之服務。
2. (B) 下列關於「資產」的敘述，何者符合 ISO/CNS 27002 標準的定義？
 - (A) 資產限於硬體和軟體等實體項目。
 - (B) 資產被定義為對組織有價值的任何事物。
 - (C) 主要資產僅指資訊，不包含營運流程與活動。
 - (D) 支援資產不包含人員和場域等要素。
3. (C) 建立資通安全的危機意識的重要性，以下何者「錯誤」？
 - (A) 資安的危害可能產生超乎一般人的想像，造成重大影響。
 - (B) 資安攻擊無所不在，影響層面廣大。
 - (C) 資安是資安專業人員的專屬責任，與一般員工無關。
 - (D) 資安素養是現代公民需要培養的生活與工作知能。
4. (D) 資通安全的三個核心防護目標 (CIA) 是指？
 - (A) 便利性、完整性、可用性
 - (B) 機密性、有效性、整合性
 - (C) 成本性、效率性、可用性
 - (D) 機密性、完整性、可用性
5. (C) 為保護資料的「機密性」，下列哪一項為其主要措施？
 - (A) 雜湊函數與數位簽章。
 - (B) 容量規劃與備份。
 - (C) 資料加解密與存取控制。
 - (D) 容錯與負載平衡。
6. (A) 當資通安全事件涉及資料被「未經授權地修改或破壞」時，這主要影響了資通安全的哪一個防護目標？

- (A) 完整性
 - (B) 機密性
 - (C) 可用性
 - (D) 法律遵循性
7. (C) 以下何者「不是」資通安全防護目標中「可用性」的主要保護措施？
- (A) 容量規劃
 - (B) 備份
 - (C) 數位簽章
 - (D) 容錯、備援及負載平衡
8. (B) 《資通安全管理法》對「資通服務」的定義為何？
- (A) 專指政府機關內部使用的資訊系統。
 - (B) 指與資訊之蒐集、控制、傳輸、儲存、流通、刪除、其他處理、使用或分享相關之服務。
 - (C) 僅指雲端運算提供的各種服務。
 - (D) 專指軟體開發與維護活動。
9. (B) 在資通安全風險意識的建立中，物聯網（IoT）的普及帶來了商機，同時也引發了哪些資安危機的思考？
- (A) 造成個人隱私洩露，但從不影響國家層面的資安風險。
 - (B) 增加被攻擊的風險，可能導致更大的不便。
 - (C) 對於軟體層面不會造成威脅，而只會對硬體設備造成威脅。
 - (D) 促進資訊自由流通，完全沒有資安隱患。
10. (C) 資通安全防護目標中的「法律遵循性」主要指的是什麼？
- (A) 資安措施的重點為遵守《資通安全管理法》，不包含其他法規。
 - (B) 確保所有資安措施都符合國際標準 ISO 27001。
 - (C) 資訊安全措施必須符合相關的法律規定，如《資通安全管理法》、《個人資料保護法》等。
 - (D) 資訊安全措施主要依循機關內部制定的資安政策與規範，不受外部法律約束。

第 2 單元：資通安全相關法規

1. (B) 我國資通安全管理體系的最高指導及協調單位是哪一個？
 - (A) 數位發展部資通安全署
 - (B) 國家資通安全會報
 - (C) 國防部資通電軍指揮部
 - (D) 內政部警政署
2. (C) 依據《資通安全管理法》，以下哪一類機關「不」屬於其適用對象？
 - (A) 關鍵基礎設施提供者
 - (B) 公營事業
 - (C) 軍事機關
 - (D) 政府捐助之財團法人
3. (C) 《資通安全管理法》的立法目的主要為何？
 - (A) 規範個人資料蒐集與利用，避免人格權侵害。
 - (B) 促進新興科技的資安技術發展。
 - (C) 提升國家整體資安防護能力，保障國家安全 and 社會公共利益。
 - (D) 該法案的立法目的完全集中於處理網路犯罪的偵查與防制。
4. (D) 依據《資通安全管理法施行細則》，公務機關與特定非公務機關在資通安全事件發生「事前」應辦理的共同義務為何？
 - (A) 提出改善報告。
 - (B) 接受資通安全稽核。
 - (C) 提交資通安全事件調查報告。
 - (D) 訂定資通安全維護計畫及通報應變機制。
5. (B) 依據《資通安全管理法》規定，公務機關除了資安長外，還需設置什麼人員？
 - (A) 資安專責人員（非專職）
 - (B) 資安專職人員
 - (C) 公關經理
 - (D) 法律顧問
6. (C) 《資通安全管理法施行細則》第 7 條對「核心資通系統」的定義中，以下何者「不」是判斷標準？

- (A) 支持核心業務持續運作必要之系統。
 - (B) 依資通安全責任等級分級辦法判定防護需求等級為高者。
 - (C) 一般行政作業的辦公室軟體之必要功能。
 - (D) 業務涉及全國性民眾服務或跨公務機關共用性資通系統之維運。
7. (C) 依據《資通安全責任等級分級辦法》，各機關應多久提報或核定其資通安全責任等級 1 次？
- (A) 每年
 - (B) 每 2 年
 - (C) 每 3 年
 - (D) 每 5 年
8. (C) 關於《個人資料保護法》的目的，以下何者敘述「最完整」？
- (A) 其主要目的為避免人格權受侵害，與個人資料之利用無關。
 - (B) 其主要目的為促進個人資料之合理利用，不涉及人格權的保護。
 - (C) 為規範個人資料之蒐集、處理及利用，以避免人格權受侵害，並促進個人資料之合理利用。
 - (D) 為積極推動國家資通安全政策。
9. (B) 比較《個人資料保護法》與《資通安全管理法》，關於其主管機關的敘述，何者正確？
- (A) 兩者主管機關皆為數位發展部。
 - (B) 《個人資料保護法》主管機關為個人資料保護委員會（含籌備機制），《資通安全管理法》主管機關為數位發展部。
 - (C) 《個人資料保護法》主管機關為法務部，《資通安全管理法》主管機關為內政部。
 - (D) 兩者皆無特定主管機關。
10. (C) 依據《國家機密保護法》，以下哪一個是「絕對機密」的最長保密期限？
- (A) 10 年
 - (B) 20 年
 - (C) 30 年
 - (D) 永久保密

第 3 單元：資通安全風險管理

1. (C) 在資通安全風險管理中，「風險」的定義是什麼？
 - (A) 威脅本身的存在。
 - (B) 資產的脆弱性。
 - (C) 威脅利用其相對應脆弱性，造成組織或政府機關資訊資產受到衝擊的可能性。
 - (D) 資安攻擊造成的直接財務損失。
2. (B) 資通安全風險管理的最終目標是什麼？
 - (A) 達到絕對的安全性，不計成本。
 - (B) 在最低的防護成本投入下獲得最佳化的安全性。
 - (C) 將所有資安風險完全消除。
 - (D) 以符合法規最低標準為目標，不考慮其他資安提升措施。
3. (C) 在風險管理的全景建立中，進行風險評鑑與實作資安各項防護控制措施前，應識別哪些方面的安全需求？
 - (A) 識別資安需求時，主要關注組織內部環境，不包括外部因素。
 - (B) 識別資安需求時，主要關注外部環境，不包括內部因素。
 - (C) 應識別機關內、外各方面的安全需求。
 - (D) 識別資安需求時，重心放在技術能力與經費預算，可忽略其他重要方面。
4. (B) 關於「高階風險評鑑」方法的優點，以下何者敘述不正確？
 - (A) 一開始採用較簡便作法，容易獲得參與人員接受。
 - (B) 評鑑結果較為精確，能識別所有營運過程或系統的潛在風險。
 - (C) 把握時效，讓最關鍵且需受保護的資通系統優先被提出與實作。
 - (D) 可將資源與預算運用於最有利之處。
5. (A) 在資通系統安全等級設定中，若某資通系統資料外洩將「危及國家安全」，或涉及「特殊屬性之個人資料」外洩導致相關個人身心受到危害，則其「機密性」應被評定為哪個等級？
 - (A) 高級
 - (B) 中級
 - (C) 普級
 - (D) 無法評估

6. (C) 下列哪種風險評鑑作法是對資產進行深度識別與鑑別，並詳細列出可能面臨威脅與可能存在的弱點？
- (A) 高階風險評鑑作法
 - (B) 普級風險評鑑作法
 - (C) 詳細風險評鑑作法
 - (D) 簡易風險評鑑作法
7. (C) 在建立風險評鑑組織時，建議應如何組建，以避免產出結果過於主觀？
- (A) 由資訊人員或資安人員全權執行，不需徵詢其他部門的意見。
 - (B) 由單一成員執行所有資通系統風險評鑑工作。
 - (C) 建議成立「跨部門」風險評鑑組織，並宜包含熟悉業務的承辦人員。
 - (D) 由高層主管主導評鑑，不需納入跨部門的多元觀點。
8. (D) 當機關面對風險時，若決定不採取額外行動，而是接受風險可能帶來的後果，這種風險處理方式稱為什麼？
- (A) 風險修改
 - (B) 風險避免
 - (C) 風險分擔
 - (D) 風險留存
9. (B) 針對社交工程攻擊，除了進行演練作業外，本課程指出最經濟有效的控制措施是什麼？
- (A) 透過部署高階防火牆即可有效防禦社交工程攻擊。
 - (B) 強化認知訓練與宣導。
 - (C) 移除所有對外連線。
 - (D) 購買資安保險。
10. (C) 將因機房設備損壞造成的損失風險轉移給保險公司，這種風險處理方式屬於哪一種？
- (A) 風險避免
 - (B) 風險修改
 - (C) 風險分擔
 - (D) 風險留存

第 4 單元：資通安全管理面暨認知與訓練應辦事項

1. (A) 依據資通安全責任等級機關應辦事項規定，A 級機關初次受核定或等級變更後，應在多久時間內完成資通系統分級並完成附表十的控制措施？
(A) 1 年內
(B) 2 年內
(C) 3 年內
(D) 無明確時程要求
2. (B) 依據附表九資通系統防護需求分級原則，當資通系統發生資安事件導致「未經授權之資訊揭露」，對機關營運、資產或信譽產生「嚴重」影響時，其「機密性」防護需求應評定為哪個等級？
(A) 普
(B) 中
(C) 高
(D) 極高
3. (B) 依據資通安全管理面應辦事項，公務機關 A 級及 B 級的「核心資通系統」應在初次受核定或等級變更後多久完成 ISO 27001 或 CNS 27001 等資訊安全管理系統的導入？
(A) 1 年內
(B) 2 年內
(C) 3 年內
(D) 無要求
4. (B) 依據《資通安全責任等級分級辦法》規定，A 級公務機關應在機關初次受核定或等級變更後多久時間內，配置幾位資通安全專職人員？
(A) 1 年內，2 人
(B) 1 年內，4 人
(C) 2 年內，2 人
(D) 2 年內，4 人
5. (A) 關於資通安全稽核的類別，以下何者是組織內部的自我檢查，通常稽核範圍為「全機關」？
(A) 第一方稽核
(B) 第二方稽核

- (C) 第三方稽核
 - (D) 外部稽核
6. (D) 業務持續運作演練中，「復原時間點目標 (RPO)」主要定義了什麼？
- (A) 系統從中斷後至恢復服務所需的最大可容忍時間。
 - (B) 完成備份還原測試所需的時間。
 - (C) 業務中斷後，對組織可能造成的最大不利衝擊時間。
 - (D) 系統可容忍資料損失的最大時間要求。
7. (C) 關於資安治理與資安管理的區分，以下何者敘述正確？
- (A) 資安治理由資安長主導，資安管理由機關首長主導。
 - (B) 資安治理負責具體執行資安措施，資安管理負責提供指導與監視。
 - (C) 資安治理從組織需求出發，提供指導與監視；資安管理負責規劃、建立、執行與監督。
 - (D) 兩者權責範圍完全相同，沒有區分必要。
8. (C) 在資安治理成熟度評估中，Level 3「標準化流程 (Established Process)」的定義為何？
- (A) 該流程尚未建立或無法達成目標。
 - (B) 該流程之執行結果已達到預先設定目標。
 - (C) 該流程已被標準化，並且已被有效地部署於組織中。
 - (D) 該流程可透過衡量結果了解執行成效，且流程已被量化管理。
9. (B) 依據資安認知與訓練應辦事項，一般使用者及主管 (A、B、C、D 級機關) 每年至少應接受多少小時的資通安全通識教育訓練？
- (A) 1 小時
 - (B) 3 小時
 - (C) 6 小時
 - (D) 12 小時
10. (C) 在業務持續運作的「管理程序」中，特別強調成功執行業務持續運作的關鍵，除了高階管理人員的認同與支持外，還需要哪些部門的投入？
- (A) 資訊部門的投入是唯一必要的。
 - (B) 成功運作僅需高階管理層和資安部門的投入，其他部門的角色無關緊要。

- (C) 必須是核心業務所有相關部門投入，而非僅是資訊部門的責任。
- (D) 外部顧問的投入足以確保成功，無需內部資源參與。

第 5 單元：資通系統防護控制措施

1. (C) 依據「事件日誌與可歸責性」之安全控制措施，機關應訂定日誌之記錄時間週期及留存政策。請問法定要求作業系統、網站或應用程式之日誌，至少應保留多長時間，以提供足夠的歷史資料供後續追溯分析？
 - (A) 至少保留 1 個月。
 - (B) 至少保留 3 個月。
 - (C) 至少保留 6 個月。
 - (D) 至少保留 1 年。
2. (D) 關於對稱式加解密演算法(如 AES)，下列何者是其主要的特點？
 - (A) 加密與解密使用不同的金鑰。
 - (B) 無法保證資料機密性。
 - (C) 加解密速度比非對稱式慢。
 - (D) 加密與解密使用同一把金鑰。
3. (A) 關於資通系統「日誌紀錄內容」的要求，以下何者是所有等級（普中高）遵循的「基本資訊內容」原則？
 - (A) 日誌應包含事件類型、發生時間、發生位置及相關使用者身分識別等資訊。
 - (B) 日誌記錄應僅限於系統層級的錯誤訊息，以減少儲存空間。
 - (C) 日誌資料只需在系統發生異常時才啟動記錄，平時可關閉。
 - (D) 日誌的輸出格式應能根據不同部門的需求，自訂多種樣式。
4. (B) 關於營運持續計畫之「復原點目標」(RPO)，主要是衡量組織對下列何者的容忍度？
 - (A) 服務中斷的時間長度。
 - (B) 資料損失的時間量。
 - (C) 維修人員到場的速度。
 - (D) 設備更新的經費。
5. (C) 在資料備份方式中，哪一種備份方式在還原時最為複雜，需要先還原最近一次的完整備份，然後依序還原所有自上次完整備份以來的備份？
 - (A) 完整備份。
 - (B) 差異備份。
 - (C) 增量備份。
 - (D) 鏡像備份。

6. (A) 為了顯著提高身分驗證的強度，降低帳號被盜用的風險，資通系統存取應採取的鑑別技術是？
- (A) 多因子鑑別技術。
 - (B) 變更預設密碼。
 - (C) 唯一識別功能。
 - (D) 帳戶鎖定機制。
7. (B) 安全系統發展生命週期 (SSDLC) 強調於專案各階段及早加入安全思維，以打造具備安全體質的資通系統。以下哪個選項「不是」SSDLC 的實作階段之一？
- (A) 需求階段。
 - (B) 銷售階段。
 - (C) 開發階段。
 - (D) 部署與維運階段。
8. (D) 關於加密金鑰或憑證的管理，以下何者敘述不正確？
- (A) 加密金鑰或憑證應定期更換。
 - (B) 避免使用萬年憑證，增加被破解風險。
 - (C) 伺服器端之金鑰保管應訂定管理規範。
 - (D) 加密金鑰與加密資料應存放在同一位置，方便管理。
9. (C) 關於系統漏洞修復的措施，以下何者是正確的？
- (A) 系統漏洞修復應直接在正式環境進行，以節省時間。
 - (B) 只需注意廠商的安全通告，無需關注 CVE 等網站。
 - (C) 漏洞修復應測試有效性及潛在影響，並定期更新。
 - (D) 由弱點掃描檢出之系統漏洞，無需定期追蹤修復進度。
10. (C) 在儲存媒體安全丟棄或銷毀前，應採取哪些措施以防止資料洩漏？
- (A) 刪除資料後，無需進一步處理即可安全丟棄儲存媒體。
 - (B) 對儲存媒體進行實體破壞後，不須確認資料是否已被徹底銷毀。
 - (C) 應先安全的刪除資料或進行實體的破壞。
 - (D) 無需特別處理，直接丟棄即可。

第 6 單元：資通安全技術面應辦事項-資通安全防護及偵測

1. (B) 防毒軟體在資通安全防護與偵測措施中扮演重要角色，其主要用途是防範下列哪一類的惡意程式入侵電腦軟體或系統？
 - (A) 僅限於防範傳統型態的電腦病毒。
 - (B) 蠕蟲、間諜軟體、後門程式及木馬程式。
 - (C) 主要用於加密網路通訊，而非防範惡意程式。
 - (D) 僅限於防範勒索軟體，不包含其他惡意程式。
2. (D) 關於防毒軟體的管理重點，以下哪項敘述是不正確？
 - (A) 應定期自動更新病毒碼。
 - (B) 病毒感染的事件與趨勢應定期分析。
 - (C) 應避免未安裝防毒軟體的電腦上線。
 - (D) 「個人電腦與伺服器防毒系統」與「防毒匣道系統」應採用相同廠牌以簡化管理。
3. (B) 網路防火牆的主要功能是什麼？
 - (A) 其唯一功能是監測內部網路的流量，不涉及外部連線。
 - (B) 限制不必要的服務埠號開啟，僅允許必要的服務連線。
 - (C) 網路防火牆的功能僅限於阻擋已知的惡意軟體入侵。
 - (D) 主要用於加密網路通訊。
4. (C) 關於網路防火牆的管理重點，以下哪項是確保其安全有效運作的關鍵？
 - (A) 防火牆存取規則的變更無需管理程序。
 - (B) 防火牆存取紀錄無需即時匯出，定期備份即可。
 - (C) 定期產出異常存取統計分析報表，進行異常處理。
 - (D) 防火牆存取控管規則終身無需盤查。
5. (B) 電子郵件過濾機制的核心管理重點之一，是如何處理其規則的變更？
 - (A) 規則變更由系統自動完成，無需人工介入。
 - (B) 規則變更應建立管理程序，包含變更申請、核准及記錄。
 - (C) 規則變更頻率越快越好，不需考量影響。
 - (D) 規則變更僅由技術人員私下進行。
6. (C) 在選購電子郵件過濾機制時，除了其判斷垃圾郵件的精準度外，建議機關還應考量哪些其他重要因素，以確保機制能全面符合業務需求？

- (A) 僅需關注是否提供基礎的郵件收發功能。
 - (B) 主要考量系統的硬體規格是否為最高級別。
 - (C) 應評估對於中文信件或多國語言的支援能力。
 - (D) 僅需確認系統的初始購買成本是否最低。
7. (C) 面對 APT (進階持續性威脅) 攻擊, 除了加強防禦, 還應具備哪種能力, 以應對攻擊後的影響?
- (A) 只需要部署單一高階資安設備即可全面應對。
 - (B) 提升系統效能以加速攻擊。
 - (C) 透過備份管理等機制進行快速復原。
 - (D) 減少資安事件日誌紀錄。
8. (B) 為了有效防禦 APT 攻擊, 透過哪種機制可提升安全防禦策略及戰略的部署?
- (A) 完全依賴內部資安團隊的分析, 不參考外部資訊。
 - (B) 透過跨機關的資安聯防機制、情資的交換機制。
 - (C) 專注於修補已知漏洞, 不需情資共享。
 - (D) 減少對外部威脅情資的關注。
9. (C) 關於「政府組態基準 (GCB)」的目的和部署範圍, 以下敘述何者不正確
- (A) GCB 目的在於發展一致性安全組態設定。
 - (B) GCB 可提升政府機關資通訊設備之資安防護。
 - (C) GCB 部署範圍僅限於伺服器。
 - (D) GCB 的導入是 A 級與 B 級公務機關必須辦理的事項。
10. (B) 在組態變更管理中, 當 IT 系統的組態變更時, 下列哪一項層面是應特別考量的?
- (A) 進行組態變更時, 考量重點僅在於系統功能是否正常運行。
 - (B) 應考量可用性影響、安全組態影響及存取控制影響。
 - (C) 組態變更評估時, 唯一需考慮的因素是變更所產生的成本。
 - (D) 變更後無需更新組態管理資料庫。

第 7 單元：資通安全技術面應辦事項-安全性檢測及資通安全健診

1. (C) 依據資通安全責任等級規定，A 級機關的滲透測試與弱點掃描頻率為何？
 - (A) 每年 1 次滲透測試，每年 1 次弱點掃描。
 - (B) 每 2 年 1 次滲透測試，每年 1 次弱點掃描。
 - (C) 每年 1 次滲透測試，每年 2 次弱點掃描。
 - (D) 每 2 年 1 次滲透測試，每 2 年 1 次弱點掃描。
2. (B) 關於弱點掃描與滲透測試的主要差異，以下敘述何者正確？
 - (A) 弱點掃描是一種模擬攻擊，滲透測試是自動化檢測。
 - (B) 弱點掃描用於快速識別已知漏洞，滲透測試用於驗證防護措施有效性並找出可利用弱點。
 - (C) 弱點掃描主要針對內部網路，滲透測試主要針對外部網路。
 - (D) 弱點掃描不需要修補，滲透測試才需要。
3. (C) 在應用程式安全中，安全系統開發生命週期（SSDLC）的「部署與維護」階段應落實哪些重要工作？
 - (A) 擬訂資安需求與測試計畫。
 - (B) 執行風險分析與評估。
 - (C) 定期修補漏洞、升級更新版本及即時監控。
 - (D) 進行源碼掃描安全檢測。
4. (B) 為了確保變更不會成為新的風險來源，應用程式安全中的「變更控制」機制強調所有變更都需符合哪三個關鍵要素？
 - (A) 簡單、快速、有效。
 - (B) 授權、測試、記錄。
 - (C) 自動、手動、半自動。
 - (D) 規劃、執行、評估。
5. (C) 資通安全健診的目的為何？
 - (A) 資通安全健診的主要目的是處理已知的資安事件，不包括預防措施。
 - (B) 資通安全健診服務僅限於提供資通系統的漏洞掃描，不提供其他建議。
 - (C) 整合各資通安全項目的檢視服務作業，提供機關資通安全改善建議，並提升整體防護能力。

- (D) 其目的只在於評估內部人員的資安意識，不涉及系統層面的檢視。
6. (C) 在資通安全健診的「使用者端電腦惡意活動檢視」項目中，應檢視哪些內容？
- (A) 檢視內容局限於網路架構圖的安全性，不包含實際系統配置。
 - (B) 檢視惡意活動時，主要檢查伺服器主機的作業系統更新，不包括使用者端。
 - (C) 檢視作業系統及應用程式的安全性更新、是否使用停止支援的軟體、及防毒軟體狀態。
 - (D) 只需要架設封包側錄設備來觀察對外異常連線，其他方法不需使用。
7. (A) 關於網路連線安全，為何應避免使用 HTTP、FTP 和 TELNET 等協議進行敏感資料傳輸？
- (A) 這些協議採用明文傳輸，通訊內容有可能被監聽，容易造成資訊洩露風險。
 - (B) 這些協議不支援大檔案傳輸。
 - (C) 這些協議傳輸速度較慢。
 - (D) 這些協議容易受到分散式阻斷服務 (DDoS) 攻擊。
8. (C) 雲端運算具備多項核心特性，以下何者敘述是關於「受量測服務 (Measured Service)」的特性？
- (A) 雲端資源可以被快速且彈性地擴展或縮減。
 - (B) 多個客戶共享同一套基礎設施和應用程式。
 - (C) 供應商會對資源的使用情況進行監控、測量和報告，通常按照實際消耗量計費。
 - (D) 雲端服務可以透過標準的網路機制廣泛被存取。
9. (B) 在雲端安全管理中，ISO/IEC 27017:2015 標準強調了哪些關鍵考量，尤其是關於供應商與客戶的責任界線？
- (A) 雲端安全管理只關注虛擬機器的強化，不涉及其他層面。
 - (B) 雲端環境下的角色共享與權責，以及雲端服務客戶資產的移除。
 - (C) 需確保虛擬和實體網路安全管理的一致性。
 - (D) 雲端安全管理只針對管理者的操作安全進行考量，不包括客戶端的責任。

10. (C) 實體安全的三個核心防禦策略為嚇阻、延遲、偵測與處理。以下何者是屬於「嚇阻」的措施？
- (A) 感應式讀卡機。
 - (B) 設置多層門禁。
 - (C) 公布違反實體控管要求人員姓名。
 - (D) 紅外線進出感應。

第 8 單元：資訊委外安全管理

1. (C) 依據《資通安全管理法》第 10 條，機關委外辦理資通系統或服務時，應考量哪些因素來選任適當受託者並監督其維護情形？
 - (A) 唯一的考量因素是服務的價格高低。
 - (B) 選擇廠商時，只需考量其過往經驗，其他能力不重要。
 - (C) 考量受託者之專業能力與經驗、委外項目之性質及資通安全需求。
 - (D) 無需監督，全權交由廠商負責。
2. (C) 依據《資通安全管理法施行細則》第 7 條第 1 項，機關在選任及監督委外廠商時，哪些事項是需要注意的？
 - (A) 評估廠商時，僅需確認其是否具備 ISO 9001 品質認證。
 - (B) 廠商只需提供過去的合作經驗，其他資安相關資料不需評估。
 - (C) 評估廠商的資安管理能力、確認資安專業人員、以及委託終止後的資料處理方式。
 - (D) 無需關注涉及國家機密的委託業務。
3. (A) 資訊委外主要分為四大類別，以下何者是屬於「顧問訓練類」的服務形態？
 - (A) ISMS 顧問輔導。
 - (B) 機房設施管理。
 - (C) 系統開發。
 - (D) 軟體即服務 (SaaS)。
4. (B) 為降低遠端維護的資安風險，機關應採取的原則與防護措施為何？
 - (A) 原則允許、例外禁止。
 - (B) 原則禁止、例外允許，並應強化多因子鑑別。
 - (C) 無需額外防護措施。
 - (D) 遠端維護連線應該只在短天期內開放，不考慮其他條件。
5. (C) 資訊委外生命週期的「計畫階段」包含哪些關鍵步驟？
 - (A) 決標與簽約。
 - (B) 完成建置與確認營運。
 - (C) 決定需求與識別可行解決方案。
 - (D) 驗收與保固。

6. (C) 在委外資安需求識別時，為何需要「識別委外廠商之限制」？
- (A) 識別限制只是為了增加招標流程的複雜性。
 - (B) 識別限制的目的完全在於確保廠商具備足夠的技術能力。
 - (C) 依據委外業務的敏感性和法規要求，對潛在廠商設定資格限制，特別是涉及國家機密或國家安全。
 - (D) 識別限制的唯一目的是篩選出價格最低的廠商。
7. (C) 在資訊委外生命週期的「招標階段」，資安管理重點著重在哪個方面？
- (A) 招標階段的資安管理重心完全放在廠商的價格競爭。
 - (B) 資安管理重點主要在於合約條款的法律審查，不涉及技術層面。
 - (C) RFP 撰寫之完整度與評選準則中之資安要求符合度。
 - (D) 招標階段資安管理只針對最終解決方案進行選擇，不考慮前期要求。
8. (D) 在資訊委外「履約管理階段」中，機關應如何管理資訊委外的使用者存取？
- (A) 在專案初期授予委外人員最高權限，後續無需調整。
 - (B) 委外人員權限由廠商自行管理，機關無需介入。
 - (C) 機關只需透過電話確認委外人員的權限即可。
 - (D) 建立正式程序，從開始登記使用註冊，到最終不再需要存取資通系統與服務註銷。
9. (A) 在資訊委外「驗收階段」，若資通系統使用非委外廠商自行開發的第三方元件，機關應要求廠商揭露哪些資訊？
- (A) 揭露第三方程式元件之來源與授權證明，以確保其元件非來自大陸地區或其他限制地區。
 - (B) 廠商只需要揭露元件的功能說明，不需提供其他證明。
 - (C) 廠商只需要揭露元件的版本號，其他資訊不重要。
 - (D) 無需揭露，直接使用即可。
10. (C) 資訊委外專案「結束後」，機關應立即採取哪些資安措施？
- (A) 專案結束後，機關的主要任務是進行最終付款，其他資安措施可延後。
 - (B) 專案結束後，機關只需回收紙本文件，無需處理電子資料或存取權限。
 - (C) 立即停止委外廠商之實體與邏輯存取權限，並回收或銷毀屬於機

關之資訊資產。

(D) 等待保固期結束再處理。

第 9 單元：資通安全事件通報及應變

1. (D) 依據《資通安全事件通報及應變辦法》的「管理流程」，以下哪一個環節是事件發生「事前」應辦理的重要步驟？
 - (A) 進行事件的初步分級與影響分析。
 - (B) 執行事件處理過程中的通報與應變措施。
 - (C) 對已發生的事件進行改善措施與分析總結。
 - (D) 應變計畫的演練與驗證。
2. (D) 資通安全事件等級評估時，若機關的「一般公務機密或敏感資訊」遭到「嚴重洩漏」，或「國家機密」遭到洩漏，其機密性應評估為哪個等級？
 - (A) 第 1 級。
 - (B) 第 2 級。
 - (C) 第 3 級。
 - (D) 第 4 級。
3. (A) 在資通安全事件處理中，公務機關或特定非公務機關在「知悉」資安事件發生後，應在多久時間內「向上通報」相關事件資訊？
 - (A) 1 小時內。
 - (B) 2 小時內。
 - (C) 4 小時內。
 - (D) 24 小時內。
4. (C) 發生「第 3 級或第 4 級」資安事件時，上級/監督機關或中央目的事業主管機關應在多久時間內完成審核作業？
 - (A) 8 小時內。
 - (B) 4 小時內。
 - (C) 2 小時內。
 - (D) 1 小時內。
5. (C) 資通安全事件處理的「目的」之一是為了確保符合《資通安全管理法》等法律要求。此外，處理目的還包括哪些？
 - (A) 資安事件處理的唯一目的就是追溯攻擊者身分。
 - (B) 僅為降低對業務與網路服務的中斷時間。
 - (C) 確認資安事件是否發生、提供精準及時資訊、保障由政策與法律

要求的權利、實作控制措施以維護監管鏈。

(D) 處理資安事件主要目的是為了事後懲處相關人員。

6. (C) 資安事件處理後，應撰寫改善報告，其提交時限原則上為？
- (A) 3 天。
 - (B) 1 週。
 - (C) 1 個月。
 - (D) 1 年。
7. (B) 資安事件處理程序中的「封鎖 (Containment)」階段，主要目的是什麼？
- (A) 徹底清除惡意程式。
 - (B) 限制資安事件的擴散範圍，阻止損害進一步蔓延。
 - (C) 恢復受影響的系統和服務。
 - (D) 從事件中汲取教訓。
8. (C) 在處理個人資料外洩事件時，除了遵循標準處理程序外，個人資料在「復原」階段有何特殊要求？
- (A) 只需要對外發表道歉聲明，無需採取其他實質措施。
 - (B) 在復原階段，只需進行內部調查，不需通知外部受影響者。
 - (C) 應主動通知個資被外洩的對象，並提供改善方案防止進一步損害。
 - (D) 無需額外處理，等待受害者聯繫。
9. (C) 關於「數位證據」的特性，以下何者敘述正確？
- (A) 數位證據僅限於電子郵件和檔案。
 - (B) 數位證據的取得和保管無需特殊規範。
 - (C) 數位證據由電腦儲存或傳送，可用於偵查，並在法庭上具有具體用途。
 - (D) 數位證據一旦產生，其內容無法被改變。
10. (B) 社交工程攻擊主要利用了「人」的哪些弱點來達成其非法目的？
- (A) 社交工程攻擊完全是透過利用系統的技術漏洞來實現。
 - (B) 利用人性弱點，應用簡單的溝通與欺騙伎倆。
 - (C) 僅針對電腦系統進行攻擊。
 - (D) 需要具備頂尖的電腦專業技術。